

THREAT ACTOR INTELLIGENCE DOSSIER

Lazarus Group (G0032)

DPRK-Nexus Advanced Persistent Threat | Open Source Intelligence | June 2026

Classification	TLP:WHITE (public-source portfolio report)
Author	Krish Chopda
Scope	Strategic + tactical CTI profile with analyst-led IOC enrichment
Primary Focus	Attribution, victimology, ATT&CK tradecraft, infrastructure, original OSINT pivoting
Confidence	High for DPRK state nexus; moderate where subgroup boundaries or live infrastructure status are uncertain
Important Note	This is an independent student/portfolio report and is not affiliated with CrowdStrike, Microsoft, MITRE, or any vendor.

Key Judgments

KJ-1	Lazarus is best understood as a DPRK cyber enterprise, not a single narrowly bounded team. Public reporting repeatedly shows overlapping clusters that share personnel, infrastructure, malware, and tradecraft.
KJ-2	The actor has evolved from espionage and coercive disruption into industrial-scale revenue generation, with cryptocurrency and blockchain ecosystems now among its highest-value target sets.
KJ-3	The central tradecraft trend is trust abuse: fake recruiters, trojanized trading tools, signed installers, cloud/web services, and legitimate-looking infrastructure are used to reduce victim suspicion.
KJ-4	Original VirusTotal enrichment of dafom.dev supports its continued historical value as a TraderTraitor-related IOC, but the absence of exposed graph relationships highlights the limits of relying on static IOCs alone.

Visual Intelligence Overview

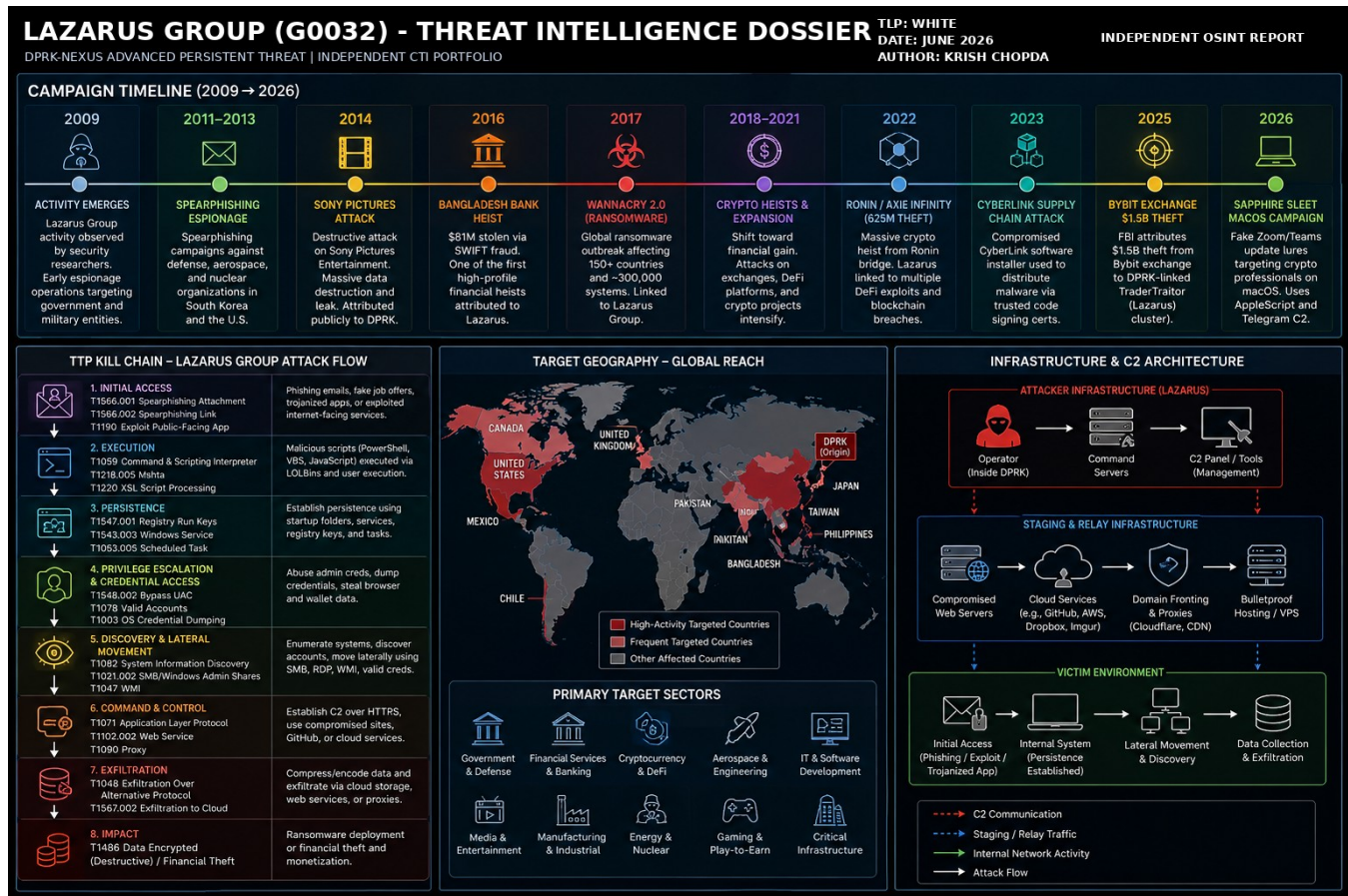


Figure 1. Unbranded intelligence overview showing campaign evolution, ATT&CK-aligned attack flow, target geography, sectors, and infrastructure model. Note: visual is a summary graphic; the written assessment below is the authoritative analytic text.

1. Executive Summary

Lazarus Group is a DPRK state-sponsored cyber actor umbrella attributed to North Korea's Reconnaissance General Bureau (RGB) with high confidence. MITRE dates Lazarus activity to at least 2009 and notes that the label is often used broadly for multiple North Korean operators, while U.S. Treasury reporting strengthens the state nexus by identifying Lazarus, Bluenoroff, and Andariel as RGB-linked entities [1][2].

The actor matters because it crosses mission boundaries that many threat profiles keep separate. Lazarus-linked activity includes strategic espionage against military, defense, aerospace, engineering, and government targets; destructive or coercive operations such as Sony Pictures and WannaCry; and revenue-generating theft against banks, cryptocurrency exchanges, DeFi platforms, and blockchain-adjacent organizations [1][3][4][6][7].

This report assesses that Lazarus has shifted from simply exploiting systems to monetizing trust. Its strongest modern playbook is not one malware family or one exploit chain. It is the repeated abuse of believable human, software, and infrastructure relationships: recruiters, signed installers, fake crypto applications, cloud services, and legitimate-looking domains.

2. Collection Methodology and Confidence

Collection consisted of open-source reporting from MITRE ATT&CK, U.S. Treasury, DOJ, FBI/IC3, CISA-linked advisories, Microsoft Security, and the analyst's own VirusTotal enrichment of a public TraderTraitor indicator. The objective was not to produce original attribution from first principles; it was to synthesize high-confidence public evidence and add transparent tactical enrichment where the analyst directly observed data.

Assessment Area	Confidence	Rationale
DPRK/RGB nexus	High	Supported by MITRE, U.S. Treasury, DOJ indictments, and repeated government/vendor correlation.
Subgroup boundaries	Moderate	Public names such as Lazarus, APT38, Bluenoroff, TraderTraitor, Diamond Sleet, and Sapphire Sleet overlap but are not perfect synonyms.
Current live infrastructure ownership	Low to Moderate	Only public IOC enrichment was performed. This report does not claim active actor control of any domain or IP without direct evidence.
Near-term targeting of crypto and software supply chains	Moderate to High	Supported by the 2022 TraderTraitor advisory, 2023 CyberLink supply-chain case, 2025 Bybit attribution, and broader trend consistency.

Analytic standard: claims are separated into evidence, assessment, and intelligence gaps. Where the evidence is incomplete, the report states the limitation rather than filling the gap with assumptions.

3. Actor Overview and Attribution

Lazarus Group should be treated as an umbrella designation for DPRK-aligned cyber operations rather than a single cleanly bounded unit. This distinction is important. A report that labels every DPRK-linked intrusion as Lazarus without preserving subgroup names loses analytic precision and makes victimology harder to interpret.

Dimension	Assessment
Origin	Democratic People's Republic of Korea (DPRK / North Korea).
State nexus	High-confidence public attribution to the RGB; Treasury

	designated Lazarus, Bluenoroff, and Andariel as North Korean state-sponsored malicious cyber groups tied to the RGB [2].
Activity window	At least 2009 per MITRE; possibly as early as 2007 per Treasury reporting [1][2].
Related names	HIDDEN COBRA, Guardians of Peace, ZINC, NICKEL ACADEMY, Diamond Sleet, Labyrinth Chollima, Bluenoroff/APT38, TraderTraitor, and others.
Core missions	Espionage, destructive disruption, financial theft, and cyber-enabled sanctions evasion.

4. Victimology: Who Lazarus Is Most Likely to Hit

The most useful targeting model is not a generic list of sectors. Lazarus prioritizes targets that satisfy at least one of three DPRK requirements: intelligence value, coercive political value, or revenue value. When a target satisfies more than one requirement - for example, a crypto firm with weak internal controls and privileged developers - its risk rises sharply.

Target Profile	Why It Matters	Representative Risk Path	Assessment
Cryptocurrency exchanges, DeFi, blockchain firms	High-value, liquid assets; transaction finality; immature governance in some organizations.	Fake recruiter or vendor lure -> employee compromise -> wallet/signing path manipulation -> laundering.	Highest near-term risk.
Software vendors and build/release environments	One compromise can reach downstream customers.	Compromised installer or update channel -> signed payload -> broad distribution.	Increasingly important.
Defense, aerospace, nuclear, engineering	Strategic intelligence aligned with DPRK military and nuclear priorities.	Spearphishing or exposed service exploitation -> credential theft -> long-term collection.	Persistent risk.
Banks and payment systems	Direct revenue generation and historical SWIFT targeting.	Initial access -> SWIFT/payment workflow manipulation -> fraudulent transfer.	Mature but still attractive.
Developers, admins, and finance operators	They hold access to code, credentials, wallets, and approval workflows.	Job lure or fake collaboration tool -> endpoint compromise -> privileged access.	High-value human targets.

5. Campaign Evolution

Lazarus campaign history tells a story of adaptation. The actor did not abandon espionage or disruption; it added financial monetization at scale. The timeline is best understood as a widening mission set rather than a clean transition from one era to another.

Year	Campaign / Activity	What It Demonstrates	Analytic Takeaway
2009+	Activity emerges in public reporting	Long-lived state-backed activity, later tracked by MITRE as G0032.	Durability and adaptability are part of the actor's threat value.
2014	Sony Pictures destructive intrusion	Data theft, coercion, destructive malware, public pressure effects.	Lazarus can use cyber operations as political signaling.
2016	Bangladesh Bank SWIFT heist	Fraudulent transfer workflow against a central bank environment.	Financial operations became strategically meaningful.
2017	WannaCry 2.0	Global ransomware/worm disruption affecting 150+ countries per public reporting.	Revenue operations can create uncontrolled systemic disruption.
2022	TraderTraitor / crypto expansion	Fake trading applications and social engineering against	Crypto became a primary

		blockchain organizations.	revenue target set.
2023	CyberLink supply-chain compromise	Modified, signed installer distributed malware using software trust.	The actor increasingly monetizes trust in software distribution.
2025	Bybit theft attributed to DPRK TraderTraitor activity	FBI publicly attributed approximately \$1.5B in virtual asset theft to DPRK activity [6].	Large-scale crypto theft remains a top DPRK cyber objective.
2026	Fake Zoom/Teams macOS lure reporting	User-driven compromise path against professionals on macOS.	The actor is adapting lures and tooling to developer and crypto work environments.

6. ATT&CK-Aligned Tradecraft

The strongest TTP finding is that Lazarus does not depend on a single exotic exploit. Its intrusion chains are effective because common techniques are combined with discipline: social engineering, scripted execution, persistence, credential theft, stealthy web-based C2, and monetization-focused post-exploitation.

Phase	Representative Techniques	Analyst Note
Initial Access	T1566.001, T1566.002, T1190, T1204.001/002	Job/recruiter lures, malicious documents, fake crypto applications, and exposed-service exploitation appear repeatedly.
Execution	T1059, T1047, T1218.005, T1220	Heavy use of PowerShell, cmd, WMI, mshta, XSL, curl, and osascript reflects preference for scriptable, living-off-the-land execution.
Persistence	T1547.001, T1543.003, T1053.005	Startup artifacts, registry run keys, services, scheduled tasks, and macOS LaunchAgents provide durable access.
Privilege / Access Expansion	T1078, T1550.002, T1548.002	Valid credentials and authentication material often matter more than one signature privilege-escalation exploit.
Defense Evasion	T1027, T1036, T1497, T1553.002	Obfuscation, packing, masquerading, sandbox checks, and code-signing abuse reduce defender confidence.
Credential Access / Discovery	T1003, T1110.003, T1082, T1046, T1087	Credential harvesting and systematic discovery enable lateral movement and targeted exfiltration.
C2 / Exfiltration / Impact	T1071, T1090, T1102.002, T1560, T1567.002, T1485	Web protocols, cloud services, proxies, archived data staging, theft, laundering, and destructive effects appear across campaigns.

7. Malware and Tooling Ecosystem

A simple malware catalog is less useful than understanding the delivery model. Lazarus blends custom tools with trusted delivery channels and dual-use utilities. That combination gives the actor flexibility: custom implants for control, legitimate tools for blending in, and signed or trusted-looking delivery to lower victim suspicion.

Tool / Malware	Role	Why It Matters
AppleJeus	Trojanized cryptocurrency applications	Connects social engineering, fake software trust, persistence, reconnaissance, and crypto theft.
TraderTraitor apps	Malicious Electron/Node.js crypto applications	Demonstrates tailored targeting of blockchain workers and trading workflows [4].
BLINDINGCAN	Remote access trojan	Representative of espionage and post-compromise control with encrypted web-

		style C2.
HOPLIGHT	Backdoor/RAT	Useful example of credential theft, proxying, WMI persistence, and pass-the-hash behavior.
ThreatNeedle / MagicRAT	Espionage and access tooling	Connects defense-sector collection to longer-term access and discovery operations.
LambLoad	CyberLink supply-chain loader	High-value evidence of signed software abuse and compromised software distribution [5].
Mimikatz, ProcDump, AdFind, WinRAR, WinSCP, PuTTY, PLINK, Stunnel	Dual-use/off-the-shelf tools	Shows the actor operationalizes normal admin and tunneling tools instead of relying only on custom malware.

8. Infrastructure and Original OSINT Investigation

The public record shows a recurring infrastructure pattern: Lazarus uses fake-brand domains, compromised legitimate websites, trusted cloud or web services, signed installers, image-hosted payload staging, and rapid cryptocurrency laundering. These patterns make static indicators useful for triage, but insufficient as the primary defensive strategy.

To move beyond secondary-source synthesis, this report includes original analyst enrichment of one public TraderTraitor indicator: <http://dafom.dev/>. The objective was not to prove attribution independently, but to validate whether the indicator still carried security value and to document what could and could not be observed from a public VirusTotal workflow.

Indicator	Observed Data	Analyst Interpretation
http://dafom.dev/	VirusTotal URL object showed 16/92 vendors flagging the URL as malicious. First seen: 2022-04-18 21:31:51 UTC. Last seen / last analysis: 2026-06-13 09:09:35 UTC. Total submissions: 137.	The URL remains useful for historical IOC correlation and retrospective threat hunting. The multi-year detection history supports continued security relevance even if current actor control is not established.
VirusTotal Graph for http://dafom.dev/	Graph displayed the URL node and Cymulate URL collections. The interface explicitly stated that the URL object did not have visible relations.	Absence of exposed relationships is a finding, not a failure. It may indicate infrastructure turnover, limited public visibility, or that richer relationships sit behind access restrictions. This reinforces the need to pair IOC review with behavioral detection.
Limitations	No Shodan, OTX, or URLScan findings are claimed in this version unless directly observed and documented by screenshots.	This prevents overclaiming. A professional report should not invent infrastructure relationships simply because public advisories list related IOCs.

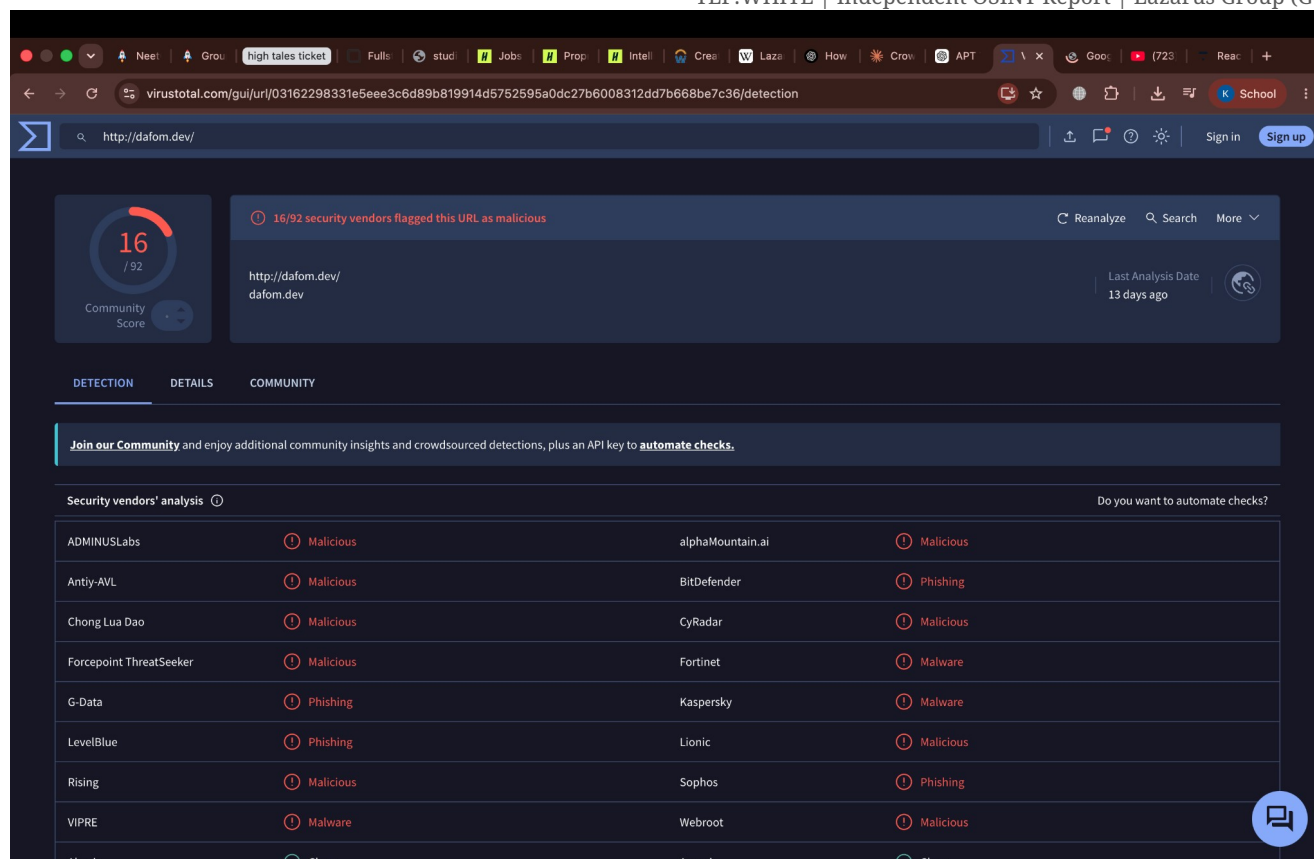


Figure 2. VirusTotal detection view for <http://dafom.dev/>, showing 16/92 vendor detections and recent analysis date.

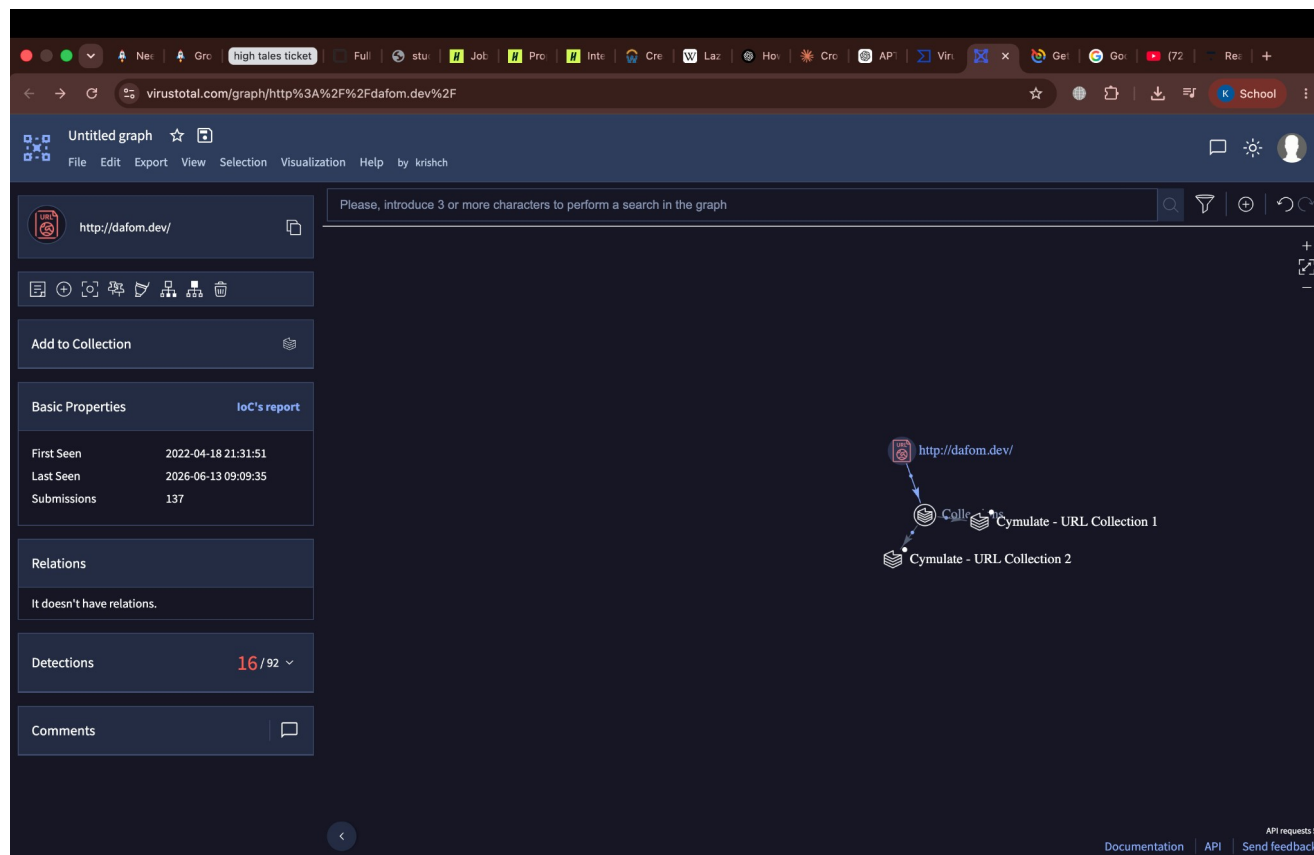


Figure 3. VirusTotal graph view for <http://dafom.dev/>, showing no publicly visible relations for the URL object at the time of analysis.

Prepared for portfolio use - not affiliated with CrowdStrike or any vendor.

9. Assessment: What the OSINT Pivot Changes

The original VirusTotal pivot does not make the report stronger because it discovers a dramatic new Lazarus server. It makes the report stronger because it demonstrates analytic discipline. The finding is modest, but it is real: dafom.dev still carries malicious vendor detections years after its original reporting, while the public graph view does not expose further infrastructure relationships.

That combination supports two practical conclusions. First, historical IOCs remain valuable for retrospective hunts, especially when an organization needs to determine whether it interacted with previously reported TraderTraitor infrastructure. Second, the lack of visible relationships shows why mature defenders should not treat IOC lists as the center of gravity. Lazarus infrastructure changes faster than analyst reports, but operator habits - job lures, trojanized apps, signed installers, credential abuse, script execution, and web-based C2 - remain more durable.

10. Defensive Priorities

Defenders should prioritize controls that disrupt Lazarus economics: make social engineering harder, reduce the blast radius of stolen credentials, protect signing and transaction workflows, and hunt for behavior that survives infrastructure turnover.

Priority	Detection / Control Focus	Why It Matters
1	Phishing-resistant MFA for external access, developers, finance operators, and crypto-signing workflows.	Credential theft and user-driven compromise appear across multiple Lazarus patterns.
2	Segment build systems, code-signing keys, release infrastructure, wallet approval paths, and payment systems.	The actor increasingly attacks trust and approval paths, not just endpoints.
3	Hunt for unusual script execution: PowerShell, cmd, WMI, mshta, rundll32, curl -> osascript, and unexpected Script Editor execution.	Scripted execution and LOLBins are recurring execution and staging behaviors.
4	Monitor persistence: startup folder LNKs, registry run keys, scheduled tasks, new services, LaunchAgents/LaunchDaemons.	Persistence patterns are more durable than individual domains.
5	Detect suspicious web C2: outbound HTTP(S) from unusual processes, GitHub/cloud service staging, Telegram Bot API egress, proxy tooling.	The actor commonly blends C2 into normal web traffic.
6	Treat recruiter lures and fake collaboration/update prompts as security scenarios, not just awareness examples.	Human trust abuse is a core intrusion vector, especially against developers and crypto personnel.

11. Intelligence Gaps and Future Collection

- Subgroup boundaries remain difficult to separate from public sources alone. Future analysis should preserve source labels such as TraderTraitor, Bluenoroff, APT38, and Diamond Sleet rather than forcing every intrusion into one Lazarus bucket.
- Live infrastructure status is not established by historical reporting. Future work should add Shodan, OTX, URLScan, Passive DNS, and certificate pivots for each public IOC.
- The VirusTotal graph view of dafom.dev did not expose relationships. Further pivots should query the domain object, historical IPs, malware hashes, and related URL collections where accessible.

- Bybit-related laundering analysis would require blockchain explorer screenshots and address clustering; without that evidence, this report does not claim original blockchain tracing.

12. Final Analyst Assessment

Lazarus should be tracked as a critical-priority actor because it can turn one access path into several different outcomes: intelligence collection, destructive effects, ransomware-style disruption, direct theft, or downstream compromise. That flexibility is what separates it from a simple malware family or a conventional criminal crew.

The actor's most important current trend is trust monetization. The same underlying logic connects AppleJeus, TraderTraitor, CyberLink, fake interview lures, and macOS update-themed activity: the victim is not only asked to run malware; the victim is persuaded to trust the mechanism that delivers it. For defenders, this means the highest-value controls are not only endpoint signatures. They are behavioral detections, identity hardening, supply-chain integrity, and workflow-level controls around the systems that move money, code, and credentials.

Based on the evidence reviewed, the most likely near-term targets are cryptocurrency firms, DeFi platforms, exchanges, venture-backed blockchain companies, software vendors, build/release environments, developers, administrators, and finance operators. Strategic espionage targeting of defense, aerospace, nuclear, engineering, and government entities should remain a standing requirement rather than be treated as a legacy mission.

Appendix A - Selected Public IOCs

Type	Indicator	Campaign / Source	Use in This Report
Domain	dafom[.]dev	TraderTraitor / CISA-linked reporting	Analyst-enriched in VirusTotal.
IP	45.14.227[.]58	Associated with dafom[.]dev in public IOC set	Future Shodan/OTX pivot target.
Domain	tokenais[.]com	TraderTraitor	Future VT/OTX pivot target.
IP	199.188.103[.]115	Associated with tokenais[.]com in public IOC set	Future Shodan/OTX pivot target.
SHA-256	166d1a6d...afb8be	CyberLink / LambLoad	Future VT graph pivot target.
SHA-256	089573b3...4e63d	CyberLink second-stage payload	Future VT graph pivot target.

Appendix B - Sources

#	Source	Link
[1]	MITRE ATT&CK: Lazarus Group (G0032)	Open source
[2]	U.S. Treasury: Treasury Sanctions North Korean State-Sponsored Malicious Cyber Groups	Open source
[3]	U.S. DOJ: North Korean Regime-Backed Programmer Charged With Conspiracy to Conduct Multiple Cyber Attacks and Intrusions	Open source
[4]	FBI/CISA/IC3: TraderTraitor Joint Cybersecurity Advisory (A22-108A / 220418)	Open source
[5]	Microsoft Security: Diamond Sleet supply chain compromise distributes a modified CyberLink installer	Open source
[6]	FBI IC3: North Korea Responsible for \$1.5 Billion Bybit Hack	Open source
[7]	Joint CSA: North Korea Cyber Group Conducts Global Espionage Campaign to Advance Regime's Military and Nuclear Programs	Open source
[8]	Analyst OSINT: VirusTotal screenshots of http://dafom.dev/ collected by Krish Chopda	Open source